

VerifyScan

Plataforma de Detecção de Golpes com Inteligência Artificial

RFC — Request for Comments

Engenharia de Software — Católica SC

Walter Theodoro Butenes Alves

Versão 1.1 · Julho de 2026

Identificação

Campo	Informação
Título do Projeto	VerifyScan — Plataforma de Detecção de Golpes com IA
Linha do Projeto	Web / IA
Autor	Walter Theodoro Butenes Alves
Data da Proposta	Maio de 2025
Versão	1.1

Sumário

Identificação	2
1. Visão do Produto e Impacto	4
1.1 Contexto e Problema	4
1.2 Origem da Demanda e Evidências	4
1.3 Análise de Soluções Existentes (Benchmark)	4
1.4 Público-Alvo	5
1.5 Objetivos do Projeto	5
1.6 Métricas de Sucesso (KPIs)	5
2. Engenharia de Requisitos	7
2.1 Personas	7
2.2 Casos de Uso Principais	7
2.3 Requisitos Funcionais (RF)	8
2.4 Requisitos Não Funcionais (RNF)	8
2.5 Regras de Negócio	9
2.6 Fora do Escopo	9
3. Fluxos e Comportamento do Sistema	10
3.1 Fluxo Principal	10
3.2 Fluxos Alternativos	11
4. Mockups e Experiência do Usuário (UX)	12
4.1 Fluxo de Navegação	12
4.2 Telas Principais	12
5. Arquitetura do Sistema	18
5.1 Visão Geral (C4 — Nível 1: Contexto)	18
5.2 Fluxo de Dados	18
5.3 Containers (C4 — Nível 2)	19
5.4 O Pipeline de Análise em Detalhe (C4 — Nível 3)	20
5.5 Modelo de Dados	25
5.6 Stack Tecnológica	26
6. Riscos do Projeto	29
7. Segurança e Privacidade	30
7.1 Privacidade e LGPD	30
8. Planejamento do Projeto	31
9. Referências	32
10. Apêndices	33
10.1 Estrutura do Repositório	33
10.2 Exemplo de Payload — ScoringEngine → AIFormulator	33
10.3 Referências Técnicas Complementares	33
11. Contribuição dos Alunos	34
12. Minhas Contribuições	38
13. Assinaturas	39

1. Visão do Produto e Impacto

1.1 Contexto e Problema

O Brasil é um dos países mais afetados por fraudes digitais no mundo. Golpes chegam por WhatsApp, SMS, e-mail, PIX, boletos falsos e lojas on-line fraudulentas, atingindo milhões de brasileiros todos os anos.

O problema central é que a maioria das pessoas não possui ferramentas acessíveis para verificar rapidamente se uma situação é segura. As alternativas atuais são fragmentadas e manuais:

- Pesquisar no Google — lento e exige alguma experiência digital
- Perguntar para alguém — nem sempre disponível ou confiável
- Consultar o Reclame Aqui — requer saber exatamente o que procurar
- Ignorar o risco — e torcer para não ser golpe

Os grupos mais vulneráveis, como idosos e pessoas com menor letramento digital, são os mais prejudicados pela ausência de uma ferramenta simples e centralizada.

“Isso é golpe?”

Uma pergunta que milhões de brasileiros fazem todos os dias sem ter uma ferramenta dedicada para respondê-la.

1.2 Origem da Demanda e Evidências

A demanda surge de um problema amplamente documentado e sentido pela população brasileira. Segundo dados do Mapa da Fraude (ClearSale, 2023), o Brasil registrou mais de 4 milhões de tentativas de fraude digital apenas no primeiro semestre de 2023.

Pesquisas informais com colegas, familiares e redes sociais revelam um padrão recorrente: as pessoas recebem mensagens suspeitas e não sabem como verificar se são golpes sem a ajuda de alguém mais experiente. O crescimento de grupos de WhatsApp e de perfis dedicados a alertar sobre golpes demonstra o interesse real do público por esse tipo de ferramenta.

1.3 Análise de Soluções Existentes (Benchmark)

Solução	Pontos Fortes	Limitações
Reclame Aqui	Base robusta de relatos de usuários	Sem IA; busca manual; não analisa links ou prints
Dfndr Security	Detecta links maliciosos no celular em tempo real	Sem análise de contexto textual

Solução	Pontos Fortes	Limitações
VirusTotal	Análise técnica profunda de URLs e arquivos	Interface técnica, pouco acessível para leigos
Phishtank	Base colaborativa de phishing atualizada	Sem suporte a linguagem natural
Google Safe Browsing	Integrado a navegadores, ampla cobertura	Não analisa contexto; apenas URLs já conhecidas

Diferencial: o VerifyScan é a única solução que combina análise de linguagem natural, verificação de links e domínios, leitura de imagens via OCR e consulta a bases de reputação externas, entregando uma resposta acessível ao usuário leigo em um único fluxo.

1.4 Público-Alvo

Perfil	Justificativa
Idosos (55+)	Grupo mais vulnerável, com menor letramento digital; alvos frequentes de golpes por WhatsApp
Adultos em geral	Expostos a golpes de PIX, boletos falsos e lojas fraudulentas
Pequenos empreendedores	Vítimas frequentes de fraudes de fornecedores e pagamentos
Qualquer pessoa	Que receba uma comunicação suspeita e precise de validação rápida

1.5 Objetivos do Projeto

Objetivo Geral

Desenvolver uma plataforma web acessível que permita a qualquer pessoa verificar, de forma rápida e simples, se está diante de uma tentativa de golpe digital.

Objetivos Específicos

- Implementar um pipeline de análise heurística próprio, capaz de processar texto, URLs, e-mails e imagens em busca de indicadores de fraude
- Integrar bases externas de reputação (VirusTotal, Google Safe Browsing) para enriquecer a análise
- Utilizar OCR para extrair e analisar texto contido em prints enviados pelo usuário
- Gerar uma pontuação de risco (baixo / médio / alto) com explicação clara, gerada por IA
- Entregar uma interface web simples e acessível, mesmo para usuários com pouca experiência digital

1.6 Métricas de Sucesso (KPIs)

Métrica	Meta
Tempo de resposta da análise	< 30 segundos por consulta
Precisão na identificação de golpes	> 85% em testes com casos reais
Usuários simultâneos suportados	Mínimo de 100, sem degradação
NPS (satisfação)	> 40 nos primeiros testes com usuários

2. Engenharia de Requisitos

2.1 Personas

Persona 1 — Dona Maria, 67 anos. Aposentada, usa WhatsApp todos os dias para falar com a família. Recebe frequentemente mensagens de promoções, cobranças e pedidos de PIX de remetentes desconhecidos. Não sabe distinguir sites falsos de verdadeiros. Seu principal objetivo é não perder dinheiro nem passar vergonha com a família por ter caído em um golpe.

Persona 2 — Carlos, 34 anos. Analista de RH, usa o celular e o computador no trabalho. Já recebeu e-mails de phishing se passando pelo banco. Tem algum letramento digital, mas não é especialista em segurança. Quer uma ferramenta rápida para verificar links suspeitos sem precisar abrir o VirusTotal e interpretar resultados técnicos.

Persona 3 — João, 45 anos. Dono de uma pequena loja. Já foi vítima de fraude de fornecedor. Recebe propostas comerciais por e-mail e WhatsApp e não tem tempo nem conhecimento para verificar a procedência de cada uma.

2.2 Casos de Uso Principais

- Enviar texto suspeito para análise
- Enviar link ou URL para verificação
- Enviar print (imagem) de mensagem suspeita
- Visualizar resultado da análise com pontuação de risco e explicação
- Consultar histórico de análises anteriores (usuário autenticado)

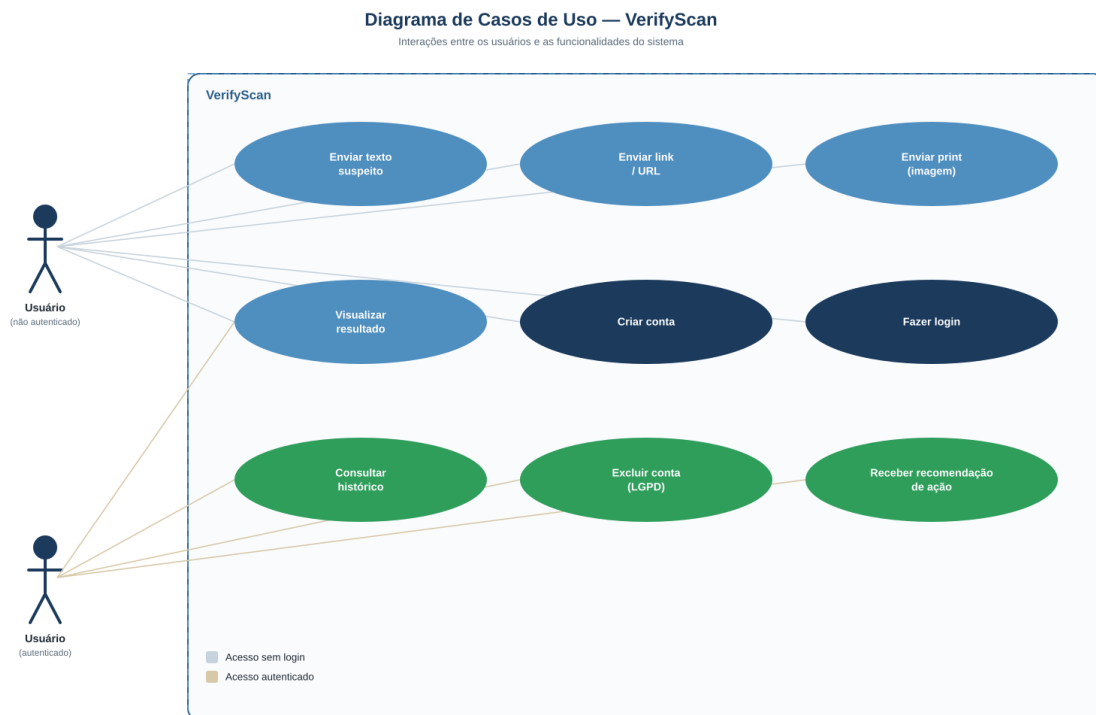


Figura 1 — Diagrama de Casos de Uso do VerifyScan

2.3 Requisitos Funcionais (RF)

ID	Descrição
RF01	O sistema deve permitir que o usuário insira texto livre descrevendo a situação suspeita
RF02	O sistema deve permitir que o usuário envie um link ou URL para análise
RF03	O sistema deve permitir que o usuário envie uma imagem (print) para análise
RF04	O sistema deve extrair o texto contido em imagens via OCR
RF05	O sistema deve identificar e extrair URLs presentes no texto e nas imagens
RF06	O sistema deve verificar URLs contra bases de dados de phishing e malware
RF07	O sistema deve analisar padrões heurísticos no texto (urgência, premiação, solicitação de dados, PIX)
RF08	O sistema deve verificar a reputação de domínios via APIs externas (VirusTotal, Google Safe Browsing)
RF09	O sistema deve gerar uma pontuação de risco: Baixo, Médio ou Alto
RF10	O sistema deve utilizar um modelo de linguagem (LLM) para transformar a pontuação e os fatores identificados pelo ScoringEngine em uma explicação em linguagem simples e acessível sobre os motivos do resultado
RF11	O sistema deve permitir que o usuário crie uma conta e faça login

ID	Descrição
RF12	O sistema deve armazenar o histórico de análises do usuário autenticado
RF13	A IA (LLM) deve receber exclusivamente o resultado estruturado da análise — pontuação, nível de risco e lista de fatores — nunca o conteúdo bruto (texto, imagem ou e-mail) enviado pelo usuário

2.4 Requisitos Não Funcionais (RNF)

ID	Descrição
RNF01	O tempo de resposta da análise deve ser inferior a 30 segundos
RNF02	O sistema deve suportar no mínimo 100 usuários simultâneos sem degradação
RNF03	O sistema deve utilizar autenticação segura, com senha criptografada (bcrypt)
RNF04	A comunicação entre frontend e backend deve ser realizada via HTTPS
RNF05	O sistema deve ser acessível em dispositivos móveis (design responsivo)
RNF06	As imagens enviadas pelo usuário não devem ser armazenadas após a análise
RNF07	O sistema deve estar disponível no mínimo 95% do tempo (uptime)
RNF08	O sistema deve permanecer operacional mesmo se a API de LLM estiver indisponível, exibindo a pontuação e os fatores identificados sem a explicação em linguagem natural (ver Seção 3.2 e Seção 6 — Riscos)

2.5 Regras de Negócio

- Usuários não autenticados podem realizar até 1 análise por sessão
- Usuários autenticados têm acesso a análises ilimitadas e ao histórico
- O algoritmo de análise deve ser executado antes da chamada à IA — a IA recebe apenas o resultado estruturado, não o conteúdo bruto
- Nenhum conteúdo enviado pelo usuário deve ser usado para treinar modelos de IA externos
- Análises sem conteúdo identificável devem retornar uma mensagem de erro informativa

2.6 Fora do Escopo

- O sistema não realizará bloqueio automático de sites ou URLs
- O sistema não atuará como antivírus nem fará análise de arquivos executáveis
- Não haverá integração nativa com WhatsApp na versão inicial (prevista para versões futuras)
- O sistema não armazenará conteúdo de terceiros citado nas mensagens analisadas

- Não será realizada análise forense de dispositivos

3. Fluxos e Comportamento do Sistema

3.1 Fluxo Principal

O fluxo principal percorre o pipeline de análise completo, da entrada do usuário até o parecer final:

1. Usuário descreve a situação suspeita (texto livre)
2. Opcionalmente, anexa link, print ou e-mail
3. OCRProcessor extrai texto de imagens (se houver)
4. URLExtractor identifica e normaliza todas as URLs
5. TextAnalyzer aplica regras heurísticas no texto
6. DomainAnalyzer verifica typosquatting, idade e TLD
7. URLChecker consulta VirusTotal e Google Safe Browsing
8. EmailAnalyzer analisa remetente e corpo (se for e-mail)
9. ScoringEngine agrega tudo e calcula a pontuação de risco
10. AIFormulator recebe o resultado estruturado e gera a resposta
11. Usuário recebe: nível de risco, explicação e recomendações

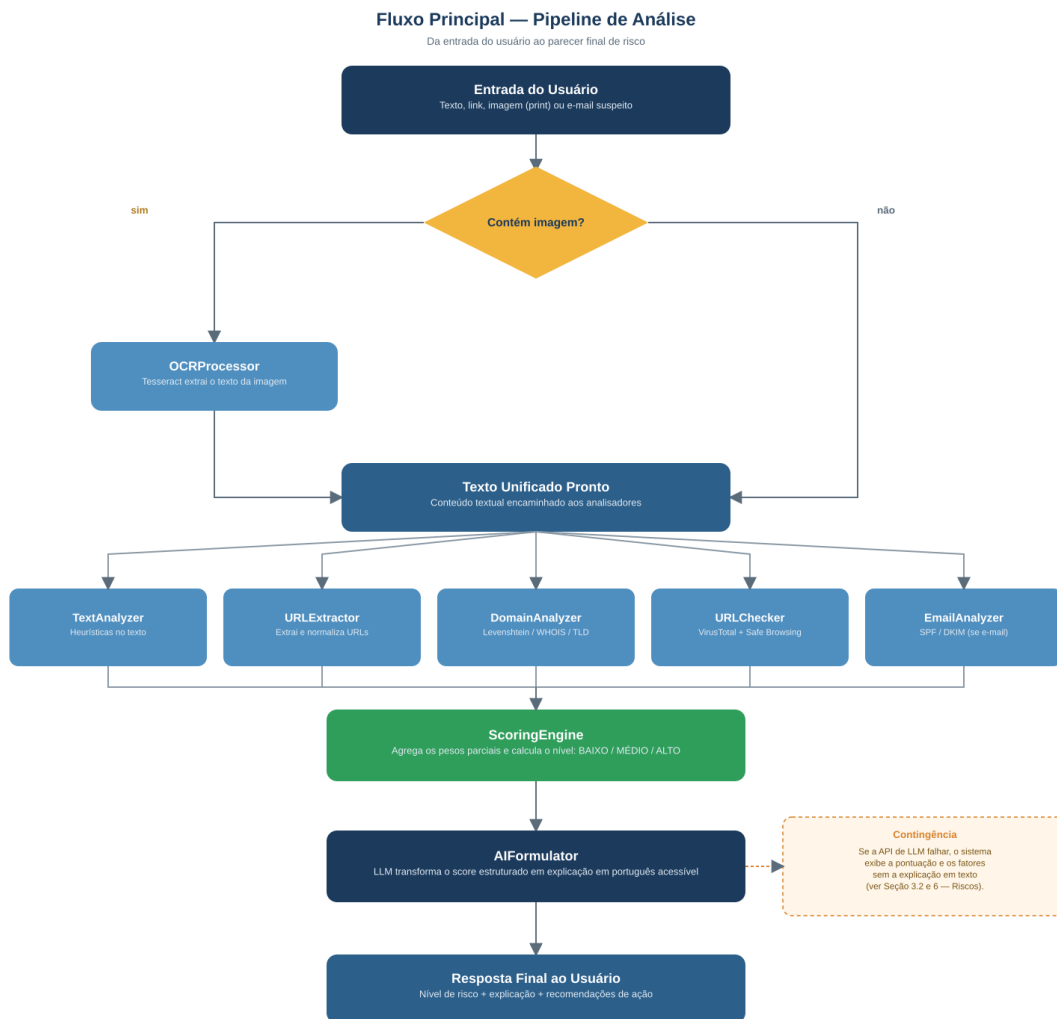


Figura 2 — Fluxo principal do pipeline de análise

3.2 Fluxos Alternativos

- **Erro na análise de imagem:** se o OCR não identificar texto legível, o sistema notifica o usuário e solicita descrição em texto
- **URL inacessível:** o sistema analisa apenas o domínio e os padrões da URL, informando a limitação
- **API externa indisponível:** a análise continua com as regras heurísticas próprias, sinalizando que a verificação externa não foi possível
- **Falha na API de LLM (novo):** se o AIFormulator não conseguir se comunicar com a LLM dentro do tempo limite, o sistema exibe a pontuação e os fatores identificados sem a explicação em linguagem natural, informando ao usuário que a explicação detalhada está temporariamente indisponível — ver RNF08 e Seção 6 (Riscos)

4. Mockups e Experiência do Usuário (UX)

4.1 Fluxo de Navegação

O usuário navega pelas telas na seguinte sequência: Página Inicial → Área de Análise → Resultado → (Opcional) Login / Cadastro → Histórico.

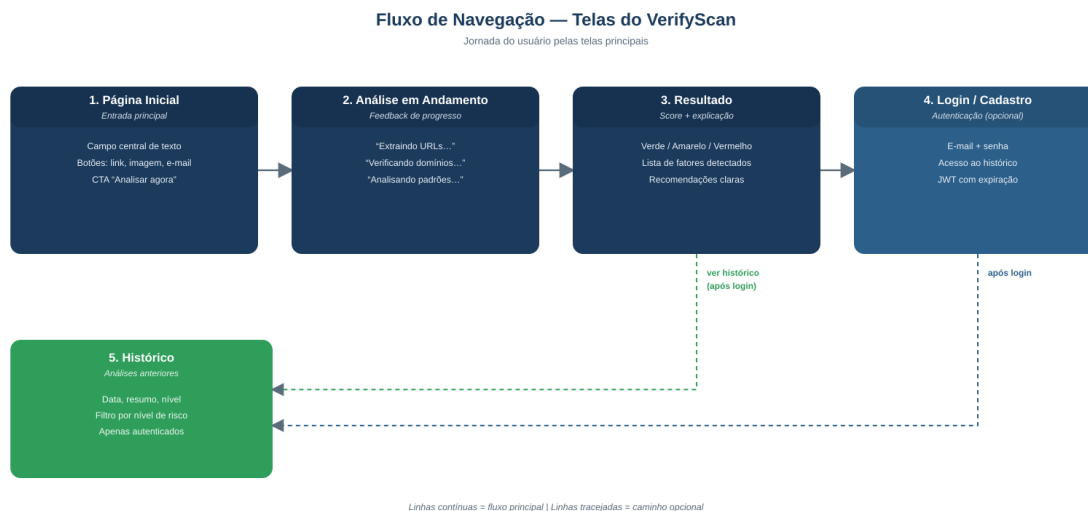


Figura 3 — Fluxo de navegação entre as telas do VerifyScan

4.2 Telas Principais

Tela 1 — Página Inicial

Campo central para inserir o texto suspeito e botões para anexar link, imagem ou e-mail. Linguagem simples e direta, com a chamada para ação “Analisar agora”.

The image shows a web browser window with the address bar displaying 'verifyscan.app'. The page has a header with the 'VerifyScan' logo on the left and an 'Entrar' button on the right. The main content area features a large heading 'Isso é golpe?' followed by the instruction 'Cole a mensagem, o link ou o print suspeito e descubra em segundos.' Below this is a text input field with the placeholder 'Cole aqui a mensagem suspeita...' and three horizontal lines representing text. Under the input field are three buttons: 'Anexar link' (with a link icon), 'Anexar imagem' (with an image icon), and 'Anexar e-mail' (with an email icon). A large, dark blue button labeled 'Analisar agora' is positioned below these options. At the bottom of the main area, it says 'Grátis · Sem cadastro para a primeira análise'. The footer contains three items: a lock icon with 'Seus dados não são armazenados', a lightning bolt icon with 'Resposta em até 30 segundos', and a Brazilian flag icon with 'Feito para o Brasil'.

Figura 4 — Tela 1: Página Inicial

Tela 2 — Análise em Andamento

Feedback visual mostrando as etapas em execução: “Extraindo URLs...”, “Verificando domínios...”, “Analisando padrões...”.

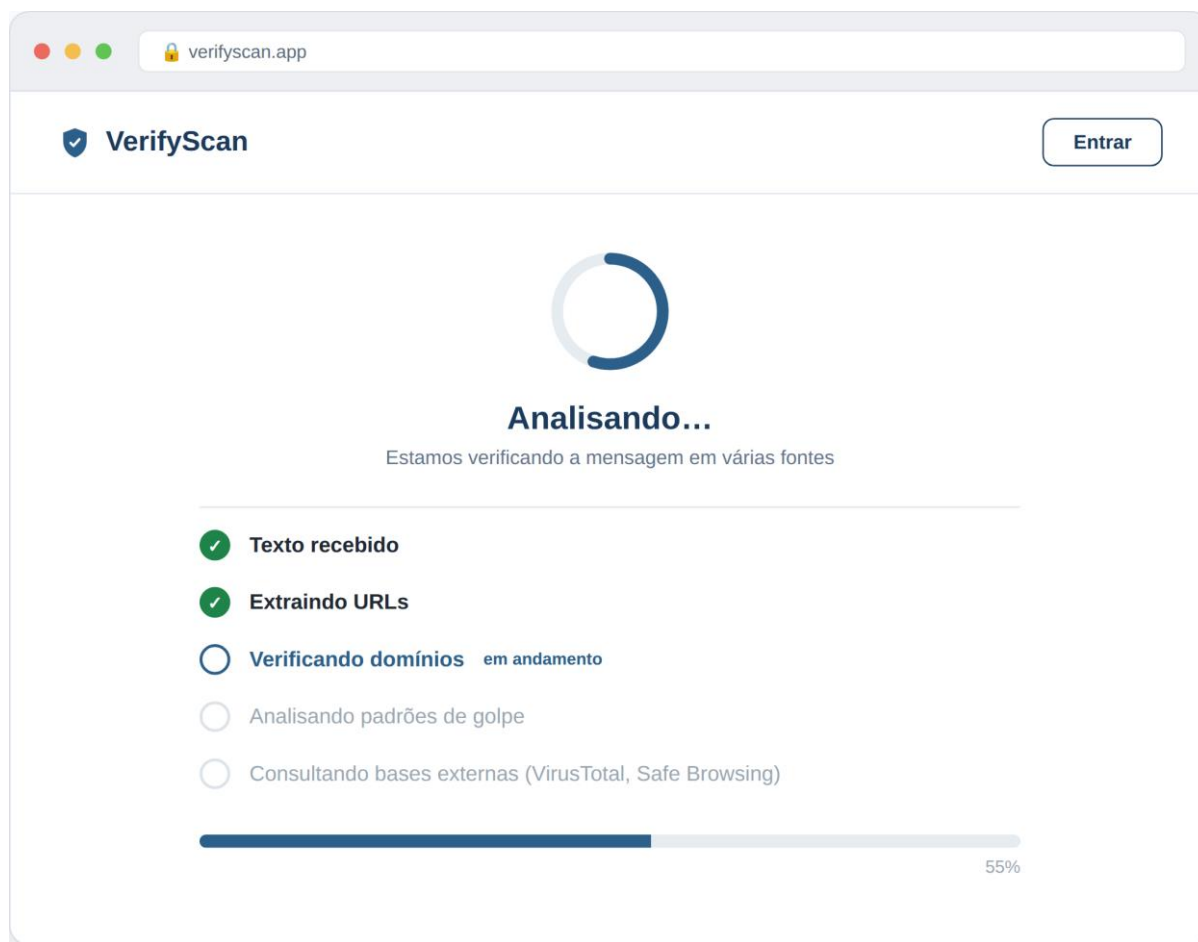


Figura 5 — Tela 2: Análise em Andamento

Tela 3 — Resultado da Análise

Nível de risco com destaque visual (verde / amarelo / vermelho), explicação em linguagem simples dos fatores identificados e recomendações de ação.

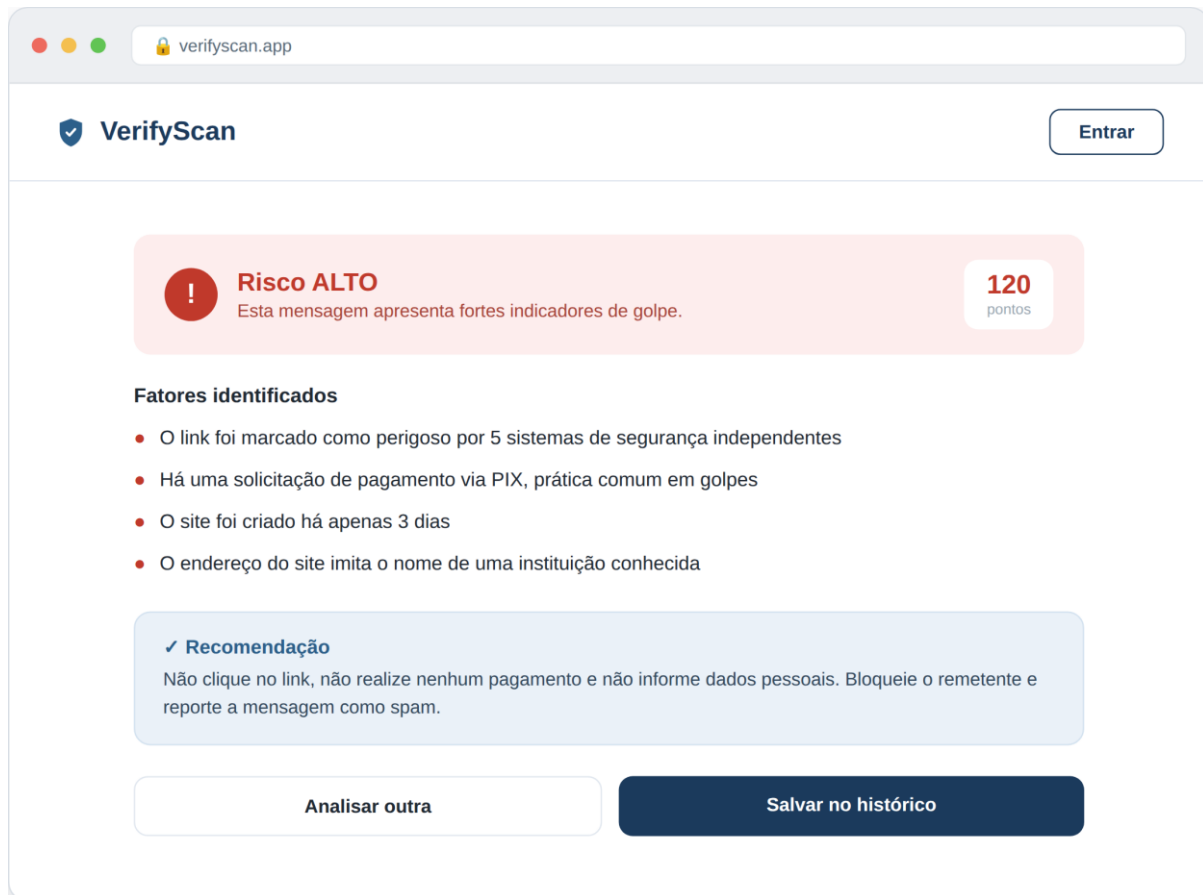


Figura 6 — Tela 3: Resultado da Análise

Tela 4 — Login / Cadastro

Formulário simples com e-mail e senha. Dá acesso ao histórico de análises.

The image shows a web browser window with the address bar displaying 'verifyscan.app'. The page has a header with the 'VerifyScan' logo on the left and an 'Entrar' button on the right. The main content area features a central shield icon with a checkmark and the text 'Bem-vindo de volta'. Below this, there are two buttons: 'Entrar' (dark blue) and 'Criar conta' (light blue). The 'Entrar' button is active. Underneath, there are two input fields: 'E-mail' with the value 'maria@email.com' and 'Senha' with masked characters '*****'. A large dark blue 'Entrar' button is positioned below the password field. At the bottom of the form, there is a link 'Esqueceu a senha?' and a footer note: 'Com uma conta você tem análises ilimitadas e acesso ao histórico.'

Figura 7 — Tela 4: Login / Cadastro

Tela 5 — Histórico

Lista de análises anteriores com data, resumo e resultado. Disponível apenas para usuários autenticados.

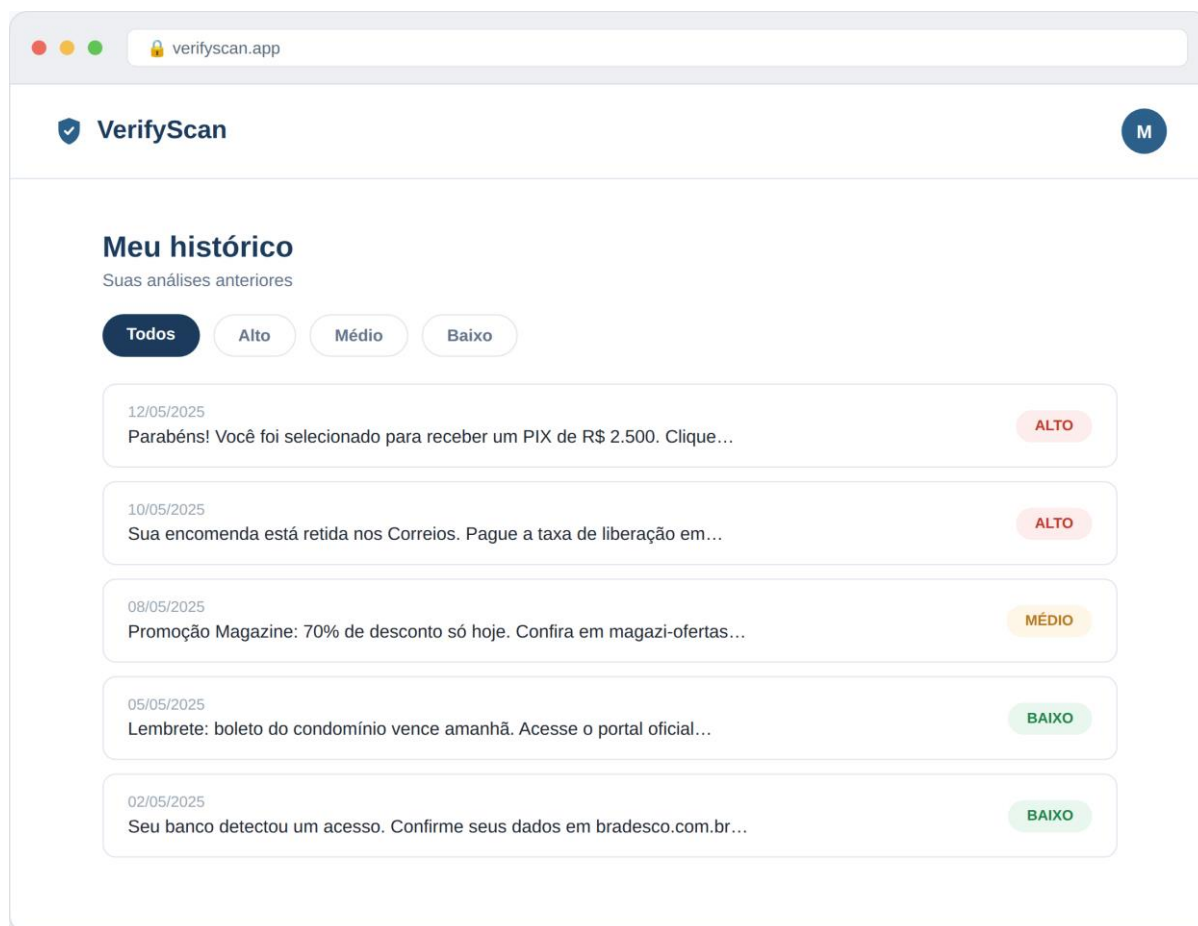


Figura 8 — Tela 5: Histórico

5. Arquitetura do Sistema

5.1 Visão Geral (C4 — Nível 1: Contexto)

Visão macro do sistema VerifyScan e suas interações com atores e sistemas externos.

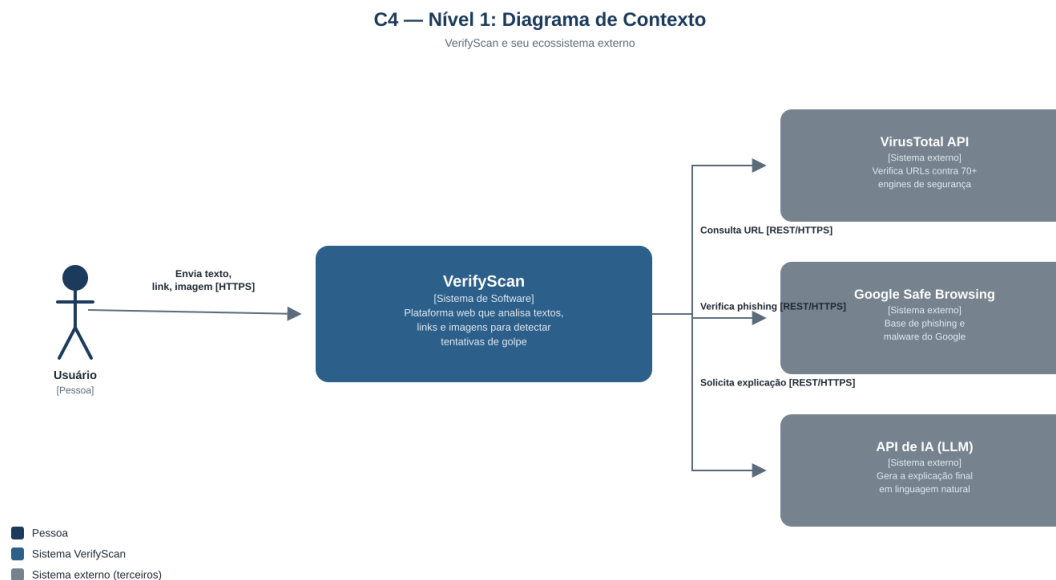


Figura 9 — C4 Nível 1: Diagrama de Contexto

Ator / Sistema	Tipo	Interação
Usuário	Pessoa	Envia texto, links e imagens; recebe o resultado da análise
VerifyScan	Sistema central	Processa, analisa e retorna o parecer de risco
VirusTotal API	Sistema externo	Verificação de URLs e domínios contra bases de malware
Google Safe Browsing	Sistema externo	Verificação de URLs conhecidas como phishing
API de IA (LLM)	Sistema externo	Geração da explicação em linguagem natural

5.2 Fluxo de Dados

Os diagramas C4 (Seções 5.1, 5.3 e 5.4) descrevem a estrutura do sistema. Esta seção complementa com uma visão mais simples, focada especificamente no caminho que o dado percorre: da entrada do usuário até o resultado exibido na tela.

O diagrama abaixo isola as quatro etapas pelas quais qualquer entrada do usuário passa, do momento em que é digitada até o momento em que o resultado aparece na tela:

- **Captura de dados** — o Frontend Web recebe o texto, link, imagem ou e-mail suspeito digitado ou colado pelo usuário
- **Processamento** — a API Backend executa o pipeline heurístico (Seção 5.4), consultando as APIs externas quando necessário
- **Armazenamento** — durante o processamento, o backend lê e grava dados no PostgreSQL (usuários e histórico) e no Redis (cache de URLs)
- **Interface do usuário** — o mesmo Frontend Web exibe o nível de risco, os fatores identificados e a recomendação

Diagrama de Fluxo de Dados — VerifyScan

Captura, processamento, armazenamento e apresentação do resultado

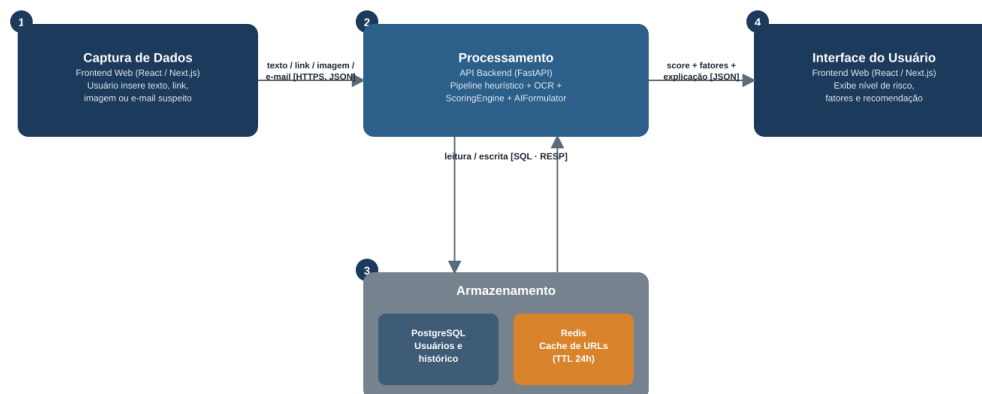


Figura 10 — Diagrama de Fluxo de Dados do VerifyScan

5.3 Containers (C4 — Nível 2)

Detalha as unidades de execução independentes que compõem o sistema e as tecnologias escolhidas.

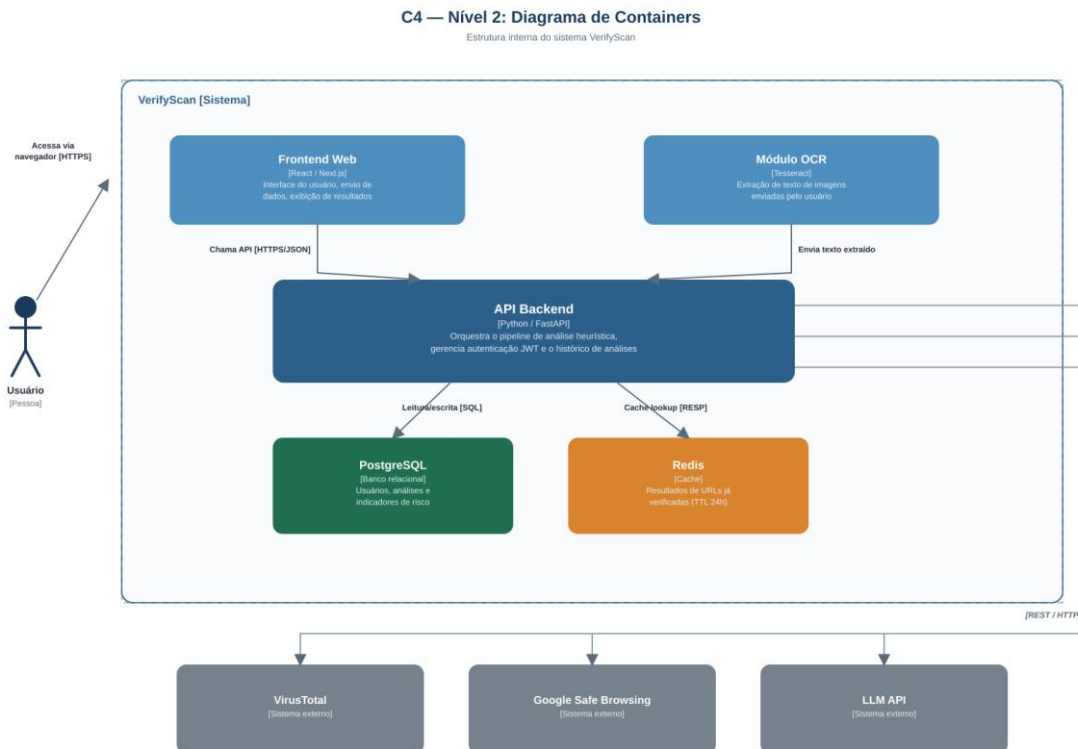


Figura 11 — C4 Nível 2: Diagrama de Containers

Container	Tecnologia	Responsabilidade
Frontend Web	React / Next.js	Interface do usuário, envio de dados, exibição de resultados
API Backend	Python / FastAPI	Orquestração do pipeline de análise
Módulo de Análise Heurística	Python	TextAnalyzer, URLExtractor, DomainAnalyzer, EmailAnalyzer
Módulo OCR	Tesseract	Extração de texto de imagens enviadas pelo usuário
ScoringEngine	Python	Agrega os resultados de todos os módulos e calcula a pontuação
AIFormulator	LLM API	Transforma o resultado estruturado em resposta acessível
Banco de Dados	PostgreSQL	Usuários e histórico de análises
Cache	Redis	Resultados de URLs já verificadas (evita chamadas repetidas)

5.4 O Pipeline de Análise em Detalhe (C4 — Nível 3)

Este é o coração do projeto

Um algoritmo próprio, com módulos independentes. Cada módulo analisa um aspecto diferente do conteúdo e retorna uma pontuação parcial; o ScoringEngine agrega tudo no final.

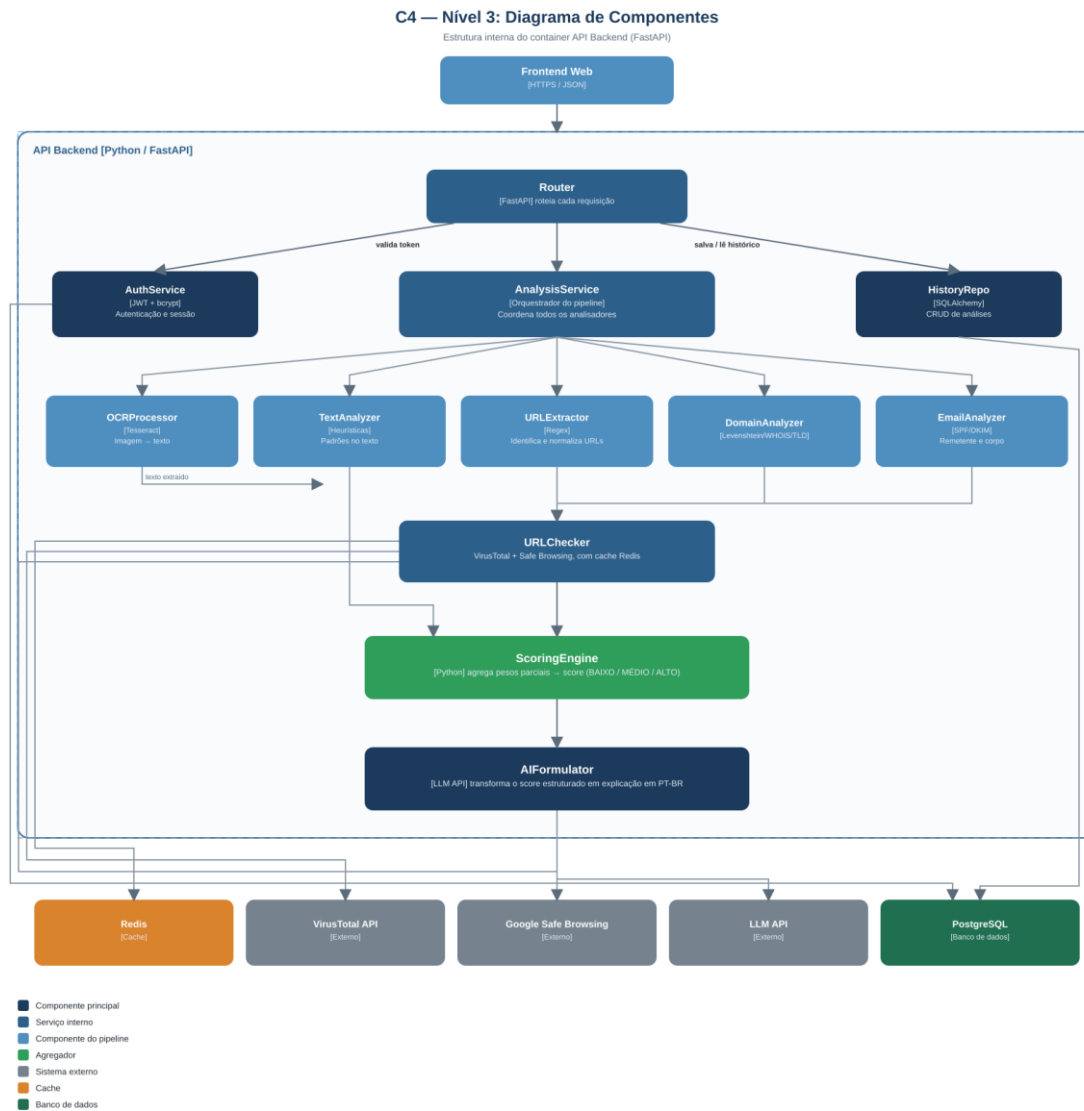


Figura 12 — C4 Nível 3: Diagrama de Componentes da API Backend

5.4.1 TextAnalyzer — Análise de Padrões no Texto

Aplica regras heurísticas sobre o texto enviado, procurando padrões linguísticos característicos de golpes. O algoritmo percorre o texto com expressões regulares e correspondência de termos. Cada padrão encontrado adiciona pontos ao score final.

Categoria	Exemplos de padrões detectados	Peso
Urgência	“clique agora”, “expira em”, “últimas horas”, “prazo vencendo”	+10

Categoria	Exemplos de padrões detectados	Peso
Personificação de marca	“Banco do Brasil informa”, “Correios — encomenda retida”	+15
Ameaça / bloqueio	“sua conta será suspensa”, “evite o bloqueio”, “última notificação”	+15
Prêmio falso	“você foi selecionado”, “parabéns, você ganhou”, “resgate seu prêmio”	+20
Solicitação financeira	“transfira”, “faça um PIX de”, “deposite”, “comprovante de pagamento”	+25
Dados pessoais	“informe seu CPF”, “confirme sua senha”, “dados bancários”	+25

5.4.2 URLExtractor — Extração de Links

Antes de analisar qualquer URL, é preciso encontrá-la no texto. O URLExtractor usa expressões regulares para identificar todos os links presentes, incluindo:

- URLs completas (https://...)
- URLs sem protocolo (www.site.com)
- URLs encurtadas (bit.ly/xxxxx, t.co/xxxxx)
- URLs embutidas em textos (“acesse aqui: site.com”)

Após a extração, cada URL é normalizada e encaminhada ao URLChecker e ao DomainAnalyzer.

5.4.3 DomainAnalyzer — Análise do Domínio

Mesmo sem consultar APIs externas, muitas fraudes são detectáveis apenas pela análise do domínio. O módulo aplica quatro verificações:

- **Typosquatting.** Compara o domínio encontrado com uma lista de marcas e instituições conhecidas (Bradesco, Itaú, Caixa, Correios, Netflix, etc.), usando o algoritmo de distância de Levenshtein. Um domínio como bradesc0.com ou itauonline.net é identificado como suspeito por ter distância de edição baixa em relação ao domínio legítimo.
- **Subdomínio enganoso.** Verifica se uma marca conhecida aparece como subdomínio, mas não como domínio principal: bradesco.conta-segura.com → domínio real = conta-segura.com → SUSPEITO.
- **TLD de alto risco.** Domínios com extensões como .xyz, .top, .click, .tk e .pw têm índice de fraude significativamente maior e somam pontos ao score.
- **Idade do domínio.** Consulta WHOIS para verificar quando o domínio foi registrado. Domínios criados há menos de 30 dias recebem pontuação adicional, pois golpistas frequentemente registram domínios novos para cada campanha.

5.4.4 URLChecker — Verificação em Bases Externas

Após a análise própria do domínio, as URLs são enviadas para verificação externa:

- **VirusTotal API.** Envia a URL para o VirusTotal, que a verifica contra mais de 70 engines de segurança. A pontuação aumenta proporcionalmente ao número de detecções.

Resultado	Pontuação
0 detecções	Sem pontuação adicional
1–2 detecções	+20 (pode ser falso positivo, mas sinaliza atenção)
3+ detecções	+40 (forte indicador de URL maliciosa)

- **Google Safe Browsing API.** API gratuita do Google que verifica se a URL está na base de phishing e malware conhecidos. Retorno positivo soma +40 ao score.
- **Cache de resultados.** Para evitar chamadas repetidas às APIs, os resultados são armazenados em cache no Redis por URL (hash SHA-256). Se a mesma URL já foi verificada recentemente, o resultado em cache é reutilizado sem nova chamada à API.

Nota de arquitetura — por que o cache vive só no Redis

O cache de URLs vive exclusivamente no Redis, como uma estrutura chave-valor não relacional, com expiração automática (TTL de 24 horas) — não há persistência equivalente em uma tabela do PostgreSQL (ver modelo de dados na Seção 5.5).

A razão é direta: o único objetivo do cache é evitar chamadas repetidas às APIs externas em um curto intervalo de tempo, como descrito acima. Persistir o mesmo dado permanentemente em uma tabela relacional duplicaria a informação sem trazer benefício — e criaria duas fontes de verdade para a mesma consulta, um risco de inconsistência maior do que o problema que o cache resolve.

5.4.5 OCRProcessor — Análise de Prints e Imagens

Muitos golpes chegam como prints de conversas de WhatsApp, SMS ou capturas de tela. O OCRProcessor resolve isso:

1. O usuário envia a imagem
2. O Tesseract OCR processa a imagem e extrai o texto visível
3. O texto extraído é encaminhado ao TextAnalyzer
4. URLs encontradas são encaminhadas ao URLExtractor → URLChecker → DomainAnalyzer
5. O resultado é tratado exatamente como se o usuário tivesse digitado o texto

O OCR funciona como uma ponte: converte imagem em texto para que os outros módulos analisem normalmente. Caso o texto extraído seja insuficiente, o sistema informa o usuário.

5.4.6 EmailAnalyzer — Análise de E-mails

Quando o usuário cola o conteúdo de um e-mail suspeito, o módulo realiza verificações específicas:

- **Análise do remetente.** Extrai o endereço do remetente e verifica se o domínio corresponde à instituição declarada: “Suporte Bradesco” <noreply@bradesco.atendimento-segura.com> → domínio real = atendimento-segura.com → não é bradesco.com.br → SUSPEITO.
- **Validação SPF/DKIM.** Se o usuário colar o cabeçalho completo do e-mail, o sistema verifica se as entradas SPF e DKIM são válidas para o domínio declarado. E-mails legítimos de grandes instituições quase sempre passam nessas validações.
- **Análise do corpo.** O texto do e-mail é passado pelo TextAnalyzer, aplicando todas as regras heurísticas.
- **Links no corpo.** Todos os links encontrados no corpo do e-mail são extraídos pelo URLExtractor e verificados pelo URLChecker e pelo DomainAnalyzer.

5.4.7 ScoringEngine — Cálculo do Risco Final

Agrega os resultados de todos os módulos e calcula a pontuação final:

Fator identificado	Pontuação
Palavra de urgência	+10
TLD de alto risco	+15
Personificação de marca	+15
Ameaça de bloqueio	+15
Prêmio ou oferta falsa	+20
Domínio criado há menos de 30 dias	+20
URL flagrada no VirusTotal (1–2 engines)	+20
Solicitação de PIX ou dados bancários	+25
Falha na validação SPF/DKIM	+25
Subdomínio enganoso	+30
Remetente de e-mail suspeito	+30
Typosquatting identificado	+35
URL flagrada no VirusTotal (3+ engines)	+40
URL flagrada no Google Safe Browsing	+40

Classificação final:

Pontuação	Nível de risco	Interpretação
0–30	Risco BAIXO	Provavelmente seguro — nenhum indicador relevante encontrado
31–60	Risco MÉDIO	Atenção recomendada — alguns indicadores presentes
61+	Risco ALTO	Forte indicativo de golpe — múltiplos fatores confirmados

5.4.8 AIFormulator — Geração da Resposta

A IA não participa da análise de risco em si — essa é uma decisão de arquitetura deliberada (Seção 2.5 e RF13). O AIFormulator recebe apenas o resultado estruturado do ScoringEngine (pontuação, nível de risco e lista de fatores) e o transforma em uma explicação clara, em português acessível, sem nunca ter contato com o conteúdo bruto enviado pelo usuário.

Entrada enviada para a IA:

```
{
  "score": 120,
  "risco": "ALTO",
  "fatores": [
    "URL flagrada no VirusTotal por 5 engines",
    "Texto contém solicitação de PIX",
    "Domínio registrado há 3 dias",
    "Typosquatting detectado: bradesc0.com"
  ]
}
```

Resposta gerada para o usuário:

Risco ALTO

Esta mensagem apresenta fortes indicadores de golpe. Identificamos os seguintes problemas: o link foi marcado como perigoso por 5 sistemas de segurança independentes; há uma solicitação de pagamento via PIX, prática comum em golpes; o site foi criado há apenas 3 dias; o endereço do site imita o nome de uma instituição conhecida.

Recomendação: não clique no link, não realize nenhum pagamento e não informe dados pessoais. Bloqueie o remetente e reporte como spam.

A escolha de provedor, a estrutura do prompt e o comportamento de contingência estão detalhados na Seção 5.6, junto da tabela comparativa entre provedores, para manter toda a decisão de stack tecnológica em um único lugar do documento.

5.5 Modelo de Dados

O modelo relacional é composto por três entidades. O cache de URLs é documentado junto ao diagrama, mas fica explicitamente fora do escopo relacional — ver nota na Seção 5.4.4.

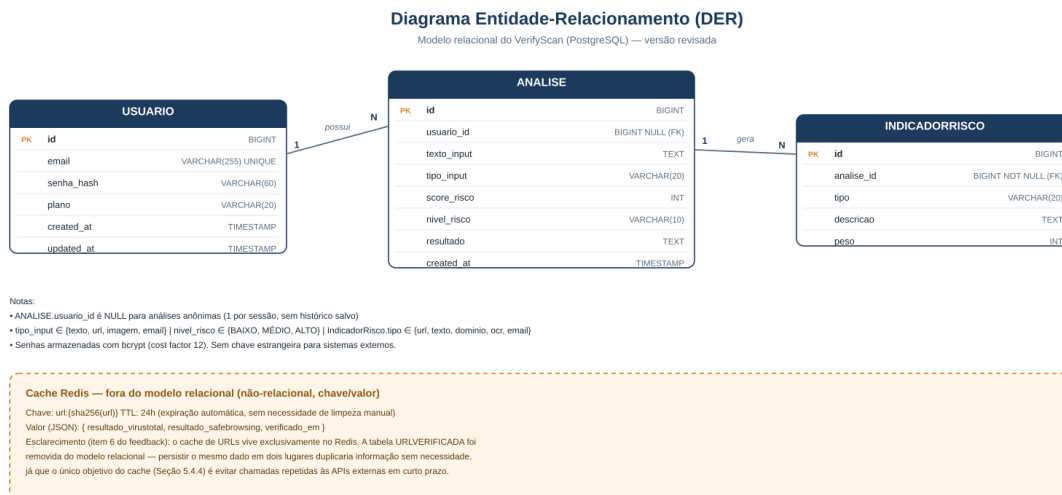


Figura 13 — Diagrama Entidade-Relacionamento (DER), versão revisada

Entidade	Atributos principais
Usuario	id, email, senha_hash, plano (gratuito/pago), created_at, updated_at
Analise	id, usuario_id (nullable), texto_input, tipo_input, score_risco, nivel_risco, resultado, created_at
IndicadorRisco	id, analise_id, tipo (url/texto/dominio/ocr/email), descricao, peso

5.6 Stack Tecnológica

Tecnologia	Uso	Justificativa
React / Next.js	Frontend	Ecossistema maduro, responsivo, boa experiência mobile
Python / FastAPI	Backend	Suporte nativo a OCR, processamento de texto e integrações de IA
Tesseract OCR	Extração de texto de imagens	Open source, com suporte ao português
VirusTotal API	Verificação de URLs	Base ampla, com API gratuita disponível
Google Safe Browsing	Verificação de URLs	API gratuita e confiável, mantida pelo Google
PostgreSQL	Banco de dados	Relacional, robusto, com suporte a JSON
Redis	Cache de resultados	Estrutura chave-valor com TTL nativo; evita chamadas repetidas às APIs externas

Tecnologia	Uso	Justificativa
Claude Haiku 4.5 (Anthropic)	Formulação da resposta (AIFormulator)	Ver comparação de provedores abaixo

Comunicação entre módulos. Protocolo e formato usados em cada integração:

De → Para	Protocolo / Formato
Frontend Web → API Backend	HTTPS / JSON (REST)
API Backend → Módulo OCR	Chamada interna (mesma linguagem, Python)
API Backend → PostgreSQL	SQL, via ORM (SQLAlchemy)
API Backend → Redis	Protocolo RESP (cliente Redis assíncrono)
API Backend → VirusTotal / Google Safe Browsing	REST / HTTPS, com timeout e retry
AIFormulator → LLM API	REST / HTTPS (JSON), com timeout de 5s e contingência (RNF08)

Provedor da LLM

Como o AIFormulator apenas transforma um JSON pequeno e já estruturado (pontuação, nível de risco e uma lista curta de fatores — normalmente algumas dezenas a poucas centenas de tokens) em um parágrafo de explicação, a tarefa não exige um modelo de raciocínio de ponta: um modelo da camada “rápida / econômica” de qualquer provedor sério é suficiente, e é o que mantém a resposta dentro da meta de 30 segundos definida na KPI da Seção 1.6, mesmo somando o tempo das etapas heurísticas anteriores. O provedor escolhido é a Anthropic, com o modelo Claude Haiku 4.5.

Critério	Anthropic — Claude Haiku 4.5	OpenAI — linha “mini / nano” (GPT-5.4)	Google — linha “Flash” (Gemini)
Adequação à tarefa (formatação leve, não raciocínio complexo)	Adequado	Adequado	Adequado
Suporte a português do Brasil	Bom	Bom	Bom
Uso de dados da API para treinamento	Não, por padrão	Não, por padrão	Não, por padrão
Categoria de custo / latência	Camada rápida / econômica	Camada rápida / econômica	Camada rápida / econômica
Escolha do projeto	Provedor principal	Alternativa configurável	Alternativa configurável

Critério de decisão: com os três provedores atendendo igualmente aos requisitos técnicos e à política de não usar dados da API para treinar modelos — alinhada à regra de negócio da Seção 2.5 — a escolha do provedor principal é uma configuração, não uma dependência rígida do pipeline. A interface do AIFormulator é simples (entrada em JSON, saída em texto), o que permite trocar de provedor sem alterar o restante da arquitetura. Os preços por token mudam com frequência entre provedores e devem ser cotados no momento da implementação; por isso este RFC fixa a categoria de modelo (camada econômica) e a política de dados como critérios de arquitetura, e não um valor absoluto de custo.

- **Estrutura do prompt.** O AIFormulator envia um prompt de sistema fixo, que instrui o modelo a: (1) escrever em português do Brasil, em linguagem simples e acessível a usuários com baixo letramento digital; (2) nunca inventar fatores que não estejam na lista recebida; (3) manter tom direto e não alarmista, mesmo em risco ALTO; (4) sempre terminar com uma recomendação de ação clara.
- **Temperatura.** Mantida baixa ($\sim 0,3$) para reduzir variabilidade e o risco de a IA “inventar” informação (alucinação), já que a tarefa é de formatação e não de criação de conteúdo.
- **Contingência.** Se a API de LLM estiver indisponível ou exceder um tempo limite de 5 segundos, o AIFormulator não derruba a análise: o sistema exibe diretamente a pontuação, o nível de risco e a lista de fatores, sem a explicação em texto corrido (RNF08, Fluxo Alternativo da Seção 3.2 e risco R-04 da Seção 6).

6. Riscos do Projeto

A tabela abaixo lista os riscos técnicos mais relevantes identificados para o VerifyScan, com impacto, probabilidade e a estratégia de mitigação prevista para cada um.

ID	Risco	Impacto	Prob.	Mitigação
R-01	APIs externas (VirusTotal, Safe Browsing) atingem limite de requisições ou ficam indisponíveis	Médio	Média	Cache Redis reduz o volume de chamadas; fallback para heurísticas próprias (Seção 3.2); timeout curto por chamada
R-02	OCR com baixa precisão em imagens de baixa qualidade (prints borrados, fotos de tela)	Médio	Alta	Pré-processamento de imagem (contraste/nitidez) antes do Tesseract; se o texto extraído for insuficiente, o sistema solicita descrição manual
R-03	Falsos positivos/negativos na pontuação heurística	Alto	Média	Ajuste contínuo dos pesos com testes em casos reais (Marco M9); indicadores individuais registrados (IndicadorRisco) para auditoria e recalibração
R-04	Indisponibilidade ou lentidão da API de LLM afeta a geração da explicação	Baixo	Média	Timeout de 5s e contingência: exibe pontuação e fatores sem o texto gerado (RNF08)
R-05	Meta de 100 usuários simultâneos não é atingida sob carga	Alto	Baixa	Chamadas às APIs externas assíncronas e em paralelo; escalonamento horizontal do API Backend; testes de carga antes da entrega final
R-06	Vazamento de dados pessoais ou não conformidade com a LGPD	Alto	Baixa	Senha com bcrypt; descarte de imagens após o processamento (RNF06); cache anonimizado por hash SHA-256; exclusão de conta sob demanda (Seção 7.1)
R-07	Domínio recém-registrado gera falso positivo (ex.: site legítimo novo)	Médio	Média	Idade do domínio é um entre vários fatores — nunca decide sozinho o nível de risco (Seção 5.4.7)
R-08	Variação de typosquatting não coberta pela lista de marcas monitoradas	Médio	Média	Lista de marcas/instituições atualizada periodicamente; complementada pela verificação externa (VirusTotal / Safe Browsing)

7. Segurança e Privacidade

- Autenticação com senha criptografada via bcrypt
- Tokens de sessão JWT com expiração
- Comunicação exclusivamente via HTTPS
- Validação e sanitização de todos os inputs (proteção contra injeção e XSS)
- Rate limiting nas rotas da API para prevenir abuso
- Imagens enviadas não são armazenadas após o processamento

7.1 Privacidade e LGPD

Dado Coletado	Finalidade	Armazenamento
E-mail e senha	Autenticação	Permanente (senha com hash)
Texto enviado	Histórico do usuário	Permanente (somente usuários autenticados)
Imagens enviadas	Processamento OCR	Temporário — descartado após a análise
URLs analisadas	Cache de resultados (Redis, TTL 24h)	Anonimizado por hash SHA-256

O usuário poderá solicitar a exclusão de sua conta e de todos os seus dados a qualquer momento, em conformidade com a LGPD (Lei nº 13.709/2018).

8. Planejamento do Projeto

Marco	Descrição	Prazo
M1	Setup do ambiente, estrutura do repositório, definição da stack	Semana 1–2
M2	Implementação do TextAnalyzer e URLExtractor	Semana 3–4
M3	Implementação do DomainAnalyzer (Levenshtein, WHOIS, TLD)	Semana 5–6
M4	Integração OCR (OCRProcessor com Tesseract)	Semana 7–8
M5	Integração das APIs externas (VirusTotal, Safe Browsing) + cache Redis	Semana 9–10
M6	EmailAnalyzer + ScoringEngine completo	Semana 11–12
M7	AIFormulator + integração com a LLM	Semana 13
M8	Frontend completo (interface web)	Semana 14–16
M9	Testes com casos reais, ajustes de precisão e UX	Semana 17–18
M10	Documentação final e apresentação	Semana 19–20

9. Referências

- VirusTotal API Documentation
- Google Safe Browsing API
- Tesseract OCR
- Algoritmo de Levenshtein — distância de edição entre strings
- OWASP Top 10
- Lei Geral de Proteção de Dados (LGPD) — Lei nº 13.709/2018
- FastAPI Documentation

10. Apêndices

10.1 Estrutura do Repositório

A organização do repositório reflete diretamente a arquitetura modular do pipeline de análise:

```

verifyscan/
├── docs/           # Diagramas C4, DER e decisões de arquitetura
├── frontend/       # Interface web (React / Next.js)
│   ├── pages/
│   ├── components/
│   └── styles/
└── backend/
    ├── analyzers/ # TextAnalyzer, URLExtractor, DomainAnalyzer, EmailAnalyzer
    ├── ocr/        # OCRProcessor (Tesseract)
    ├── scoring/    # ScoringEngine + AIFormulator
    ├── api/        # Rotas FastAPI + AuthService
    ├── models/     # Usuario, Analise, IndicadorRisco
    └── cache/      # Integração Redis

```

10.2 Exemplo de Payload — ScoringEngine → AIFormulator

Exemplo do objeto estruturado enviado à LLM para a geração da resposta final:

```

{
  "score": 120,
  "nivel_risco": "ALTO",
  "fatores": [
    { "tipo": "url", "descricao": "Flagrada por 5 engines no VirusTotal", "peso": 40 },
    { "tipo": "texto", "descricao": "Solicitação de pagamento via PIX", "peso": 25 },
    { "tipo": "dominio", "descricao": "Domínio registrado há 3 dias", "peso": 20 },
    { "tipo": "dominio", "descricao": "Typosquatting: bradesc0.com", "peso": 35 }
  ],
  "tipo_input": "texto_com_link",
  "ocr_utilizado": false
}

```

10.3 Referências Técnicas Complementares

- Levenshtein Distance
- VirusTotal API v3
- Google Safe Browsing Lookup API
- Next.js
- Mapa da Fraude 2023 — ClearSale

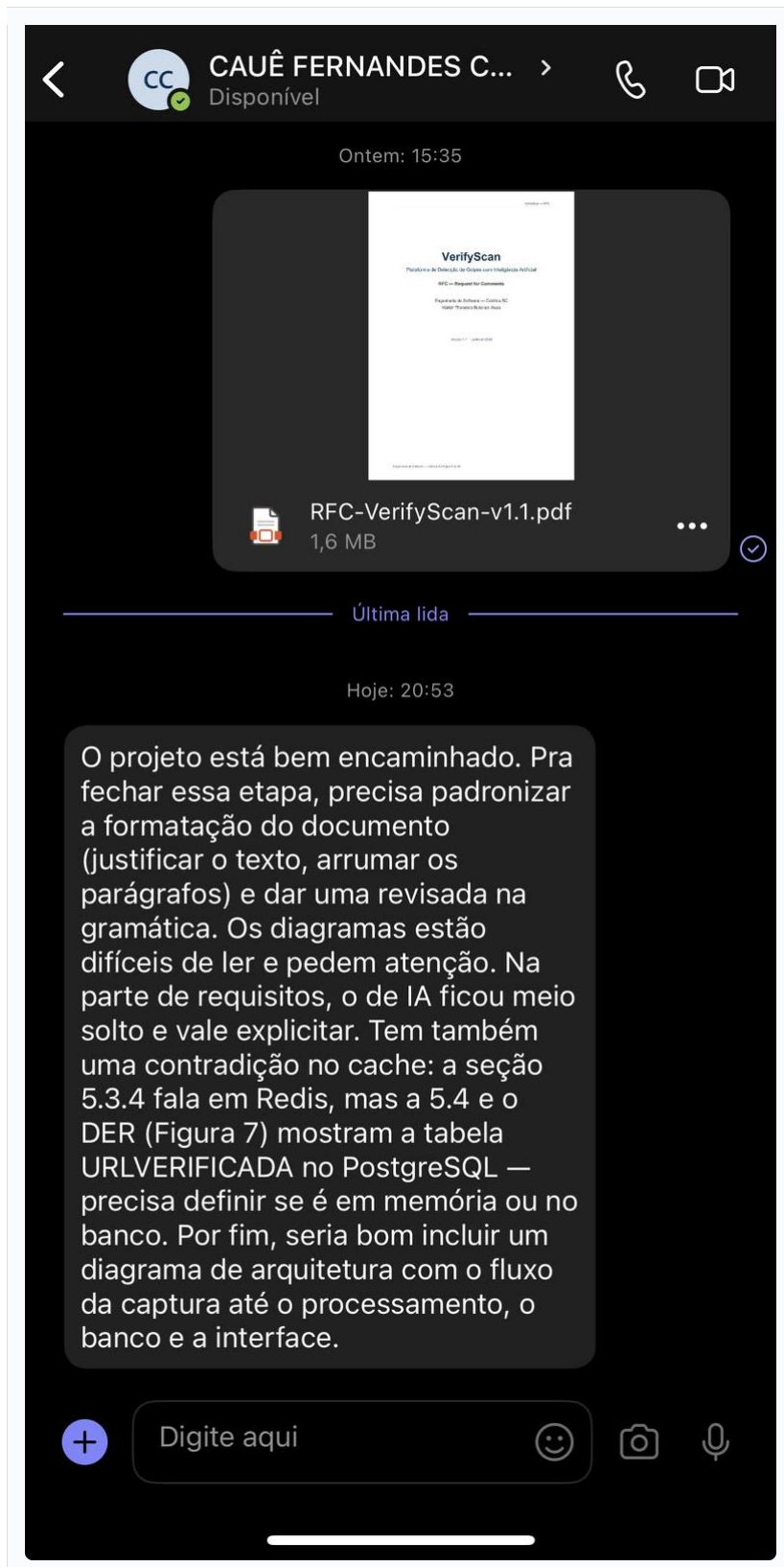
VerifyScan — porque ninguém deveria cair em golpe por falta de informação.

11. Contribuição dos Alunos

Esta seção documenta a contribuição de colegas de curso que revisaram o VerifyScan ao longo do desenvolvimento, com trechos das conversas como registro.

Cauê Fernandes Caetano

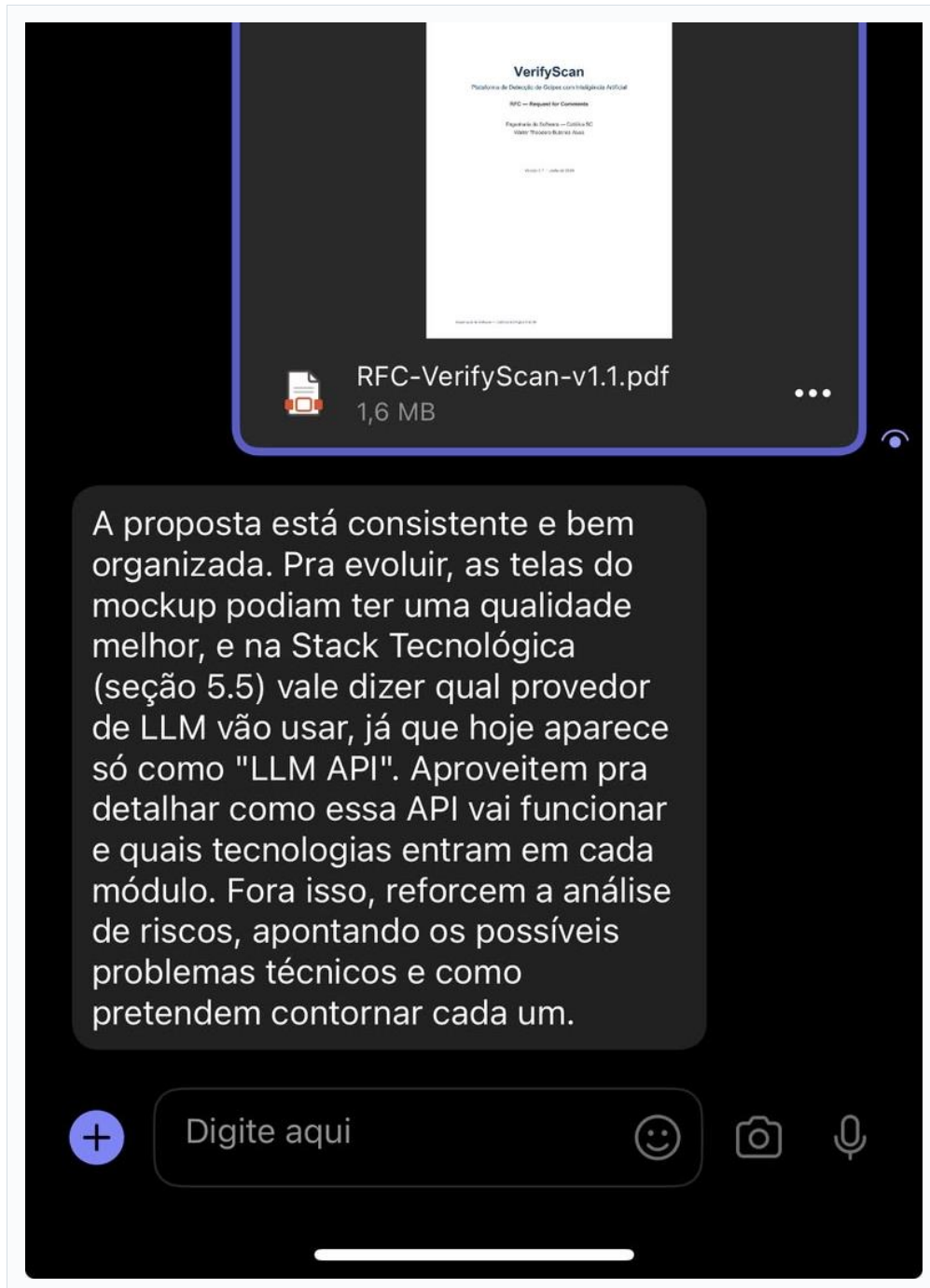
Revisou o documento e apontou pontos de formatação e legibilidade dos diagramas, a necessidade de explicitar o requisito de IA, a contradição no mecanismo de cache e a ausência de um diagrama de fluxo de dados — questões detalhadas e resolvidas nas seções correspondentes deste RFC.



Conversa com Cauê Fernandes Caetano

Luiz Fernando Passos

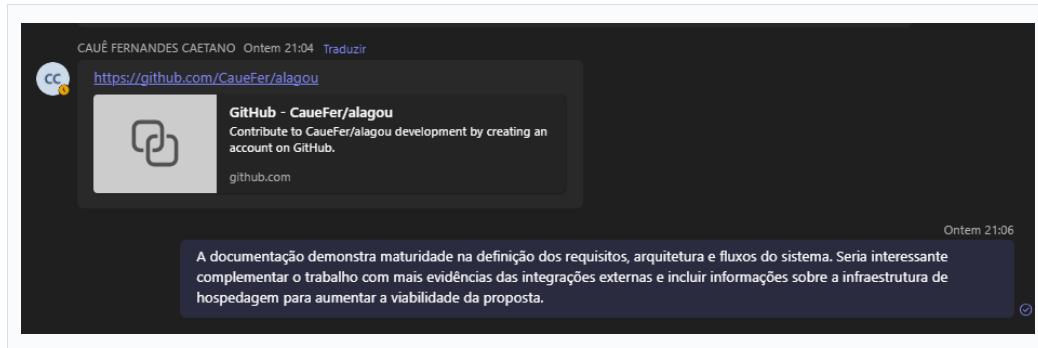
Revisou a qualidade das telas de mockup, apontou a ausência de um provedor de LLM especificado na stack tecnológica e reforçou a importância de uma análise de riscos técnicos — pontos também endereçados neste documento.



Conversa com Luiz Fernando Passos

12. Minhas Contribuições

Contribuí com uma avaliação própria sobre a maturidade da documentação e os pontos a complementar:

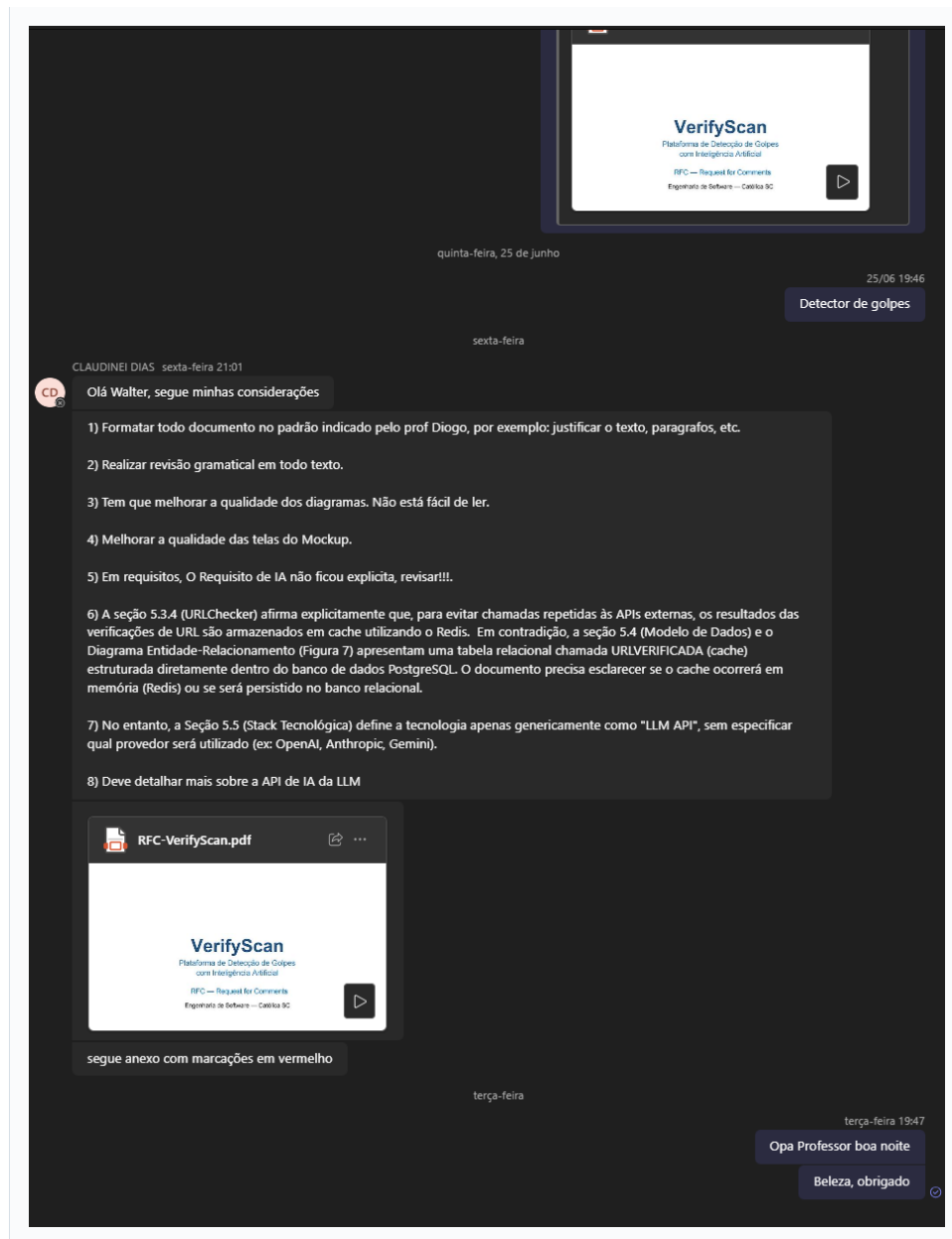


13. Assinaturas

Esta seção reúne o registro de avaliação dos professores responsáveis pela revisão do RFC.

Prof. Claudinei Dias

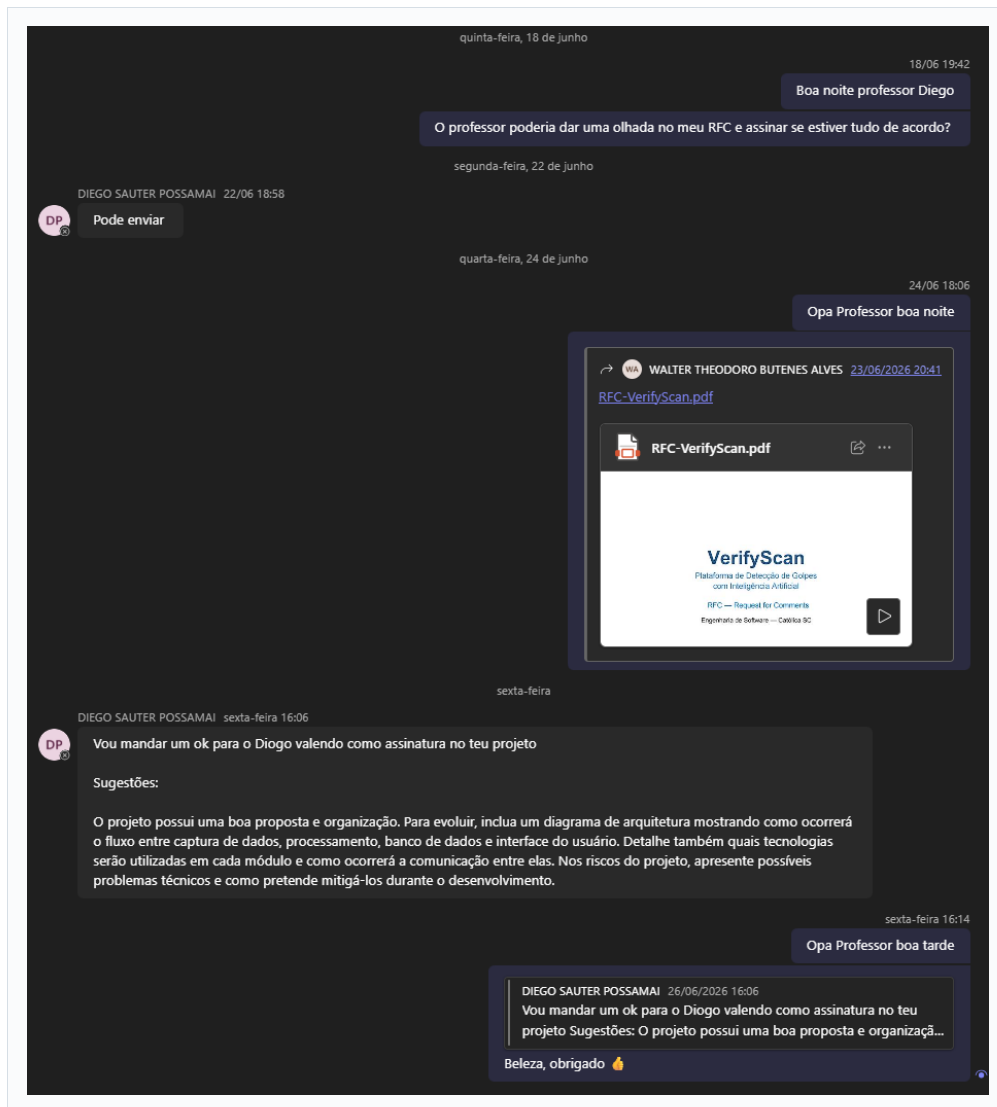
Avaliou o documento e formalizou suas orientações via chat, servindo de base para a revisão apresentada nesta versão do RFC.



Registro de avaliação — Prof. Claudinei Dias

Prof. Diego Sauter Possamai

Avaliou o projeto, encaminhou aprovação ao professor orientador responsável pela assinatura formal, e sugeriu os pontos de evolução incorporados neste documento.



Registro de avaliação — Prof. Diego Sauter Possamai